

TEAM DARK - Full Panel Configuration

Repository: ZayYadav/KeshavNoRule

Branch: TeamDarkLoader-final-panel-security

Source head: 2e7ea2705fad2ceb3844566a96559009d76458f6

Scope: Panel/server configuration only. Native Loader request/response/token contract is intentionally unchanged.

Security note: This guide contains placeholders and configuration names only. Never commit production APP_KEY, DB password, Telegram bot token, webhook secret, or native auth secret.

1. Scope and architecture

TeamDark Panel is a PHP 8.2+ / MySQL control plane for accounts, licenses, Telegram integration, optional Telegram 2FA, audit history, announcements and Owner-controlled site settings.

- Web panel: human login, dashboard, key vault, users, referrals, Owner controls and security settings.
- Loader endpoint: POST /connect using game, user_key and serial. Keep this protocol backward-compatible.
- Panel JSON API: bearer-token API for panel integrations, including 2FA continuation.
- Telegram webhook: private-chat bot for linking, 2FA, account views, announcements and optionally Owner operations.
- MySQL: accounts, encrypted license data, keyed hashes, device bindings, rate limits, audit logs, Telegram state and broadcast queues.
- APP_KEY: root server-side encryption/HMAC secret. Preserve it across normal upgrades.

2. Production requirements

- PHP 8.2+ with pdo_mysql, openssl, json and curl.
- MySQL 8.0 recommended, InnoDB and utf8mb4.
- Valid HTTPS certificate. APP_URL should use https://.
- Apache or nginx with document root pointing directly to teamdark-panel/public.
- Production display_errors=Off; detailed failures belong in server logs.
- Outbound HTTPS access to api.telegram.org when Telegram features are used.
- Dedicated non-root MySQL account; keep port 3306 private/firewalled.

3. Recommended directory and web-root layout

```
/var/www/teamdark-panel/
.env                # PRIVATE - never web served
app/                # PHP application classes
bin/                # CLI utilities only
database/           # schema.sql
public/             # WEB DOCUMENT ROOT
  index.php
  connect.php
  telegram-webhook.php
  assets/
tests/              # never public
```

Critical rule: expose only public/. Do not make the repository root, app/, bin/, database/, tests/ or .env web-accessible.

4. Fresh installation

- Deploy the branch files.
- Create a dedicated MySQL database and least-privilege DB user.
- Copy teamdark-panel/.env.example to teamdark-panel/.env.
- Generate APP_KEY and Telegram webhook secret; fill the required values.
- Import teamdark-panel/database/schema.sql.
- Create the first Owner from CLI.
- Set the web document root to teamdark-panel/public and enable HTTPS.

- Configure the Telegram webhook if Telegram is used.
- Run the validation checklist before production traffic.

Core commands

```
cd /var/www/teamdark-panel
cp .env.example .env

# APP_KEY
php -r "echo base64_encode(random_bytes(32)), PHP_EOL;"

# Telegram webhook secret
php -r "echo bin2hex(random_bytes(24)), PHP_EOL;"

# Schema
mysql -h 127.0.0.1 -u teamdark_user -p teamdark_panel < database/schema.sql

# First Owner
php bin/create-owner.php ownername 'StrongPassword12+'

# Telegram webhook (after HTTPS works)
php bin/set_telegram_webhook.php
```

5. Existing installation upgrade

- Back up the database before deploying.
 - Back up the existing .env separately.
 - Do NOT replace APP_KEY during a routine upgrade.
 - Deploy the branch files.
 - Run the same database/schema.sql once; it is the single fresh-install + upgrade file.
 - Keep TEAMDARK_AUTH_SECRET aligned with the already-deployed Loader contract.
 - Re-run the Telegram webhook utility only when APP_URL, bot token or webhook secret changes.
 - Validate login, Telegram linking, 2FA, key generation, /connect and Owner settings.
- APP_KEY warning: changing APP_KEY without a migration can make existing encrypted license material and keyed fingerprints unusable.

6. Complete .env variable reference

Current branch declares 34 environment variables in .env.example:

- APP_NAME
- APP_URL
- APP_KEY
- DB_HOST
- DB_PORT
- DB_NAME
- DB_USER
- DB_PASS
- SESSION_NAME
- SESSION_IDLE_SECONDS
- SESSION_ROTATE_SECONDS
- SESSION_ABSOLUTE_SECONDS
- REGISTRATION_BONUSES_ENABLED
- REFERRER_BONUS
- SIGNUP_BONUS
- KEY_COST
- UNLIMITED_KEY_COST
- TEAMDARK_AUTH_SECRET
- API_TOKEN_TTL
- LEGACY_LICENSE_API_ENABLED
- API_REVEAL_LICENSE_KEYS
- TELEGRAM_OWNER_MUTATIONS_ENABLED
- TELEGRAM_OWNER_SENSITIVE_READS_ENABLED
- TELEGRAM_LINKED_KEY_GENERATION_ENABLED
- TELEGRAM_GUEST_FREE_KEYS_ENABLED
- ADMIN_BALANCE_ADJUSTMENTS_ENABLED
- ADMIN_BALANCE_DAILY_LIMIT

- ADMIN_REFERRAL_BONUS_ENABLED
- AUDIT_RETENTION_DAYS
- BROADCAST_RETENTION_DAYS
- TRUSTED_PROXY_CIDRS
- TELEGRAM_BOT_TOKEN
- TELEGRAM_WEBHOOK_SECRET
- TELEGRAM_OWNER_CHAT_ID

Current safe template from branch

```

APP_NAME="TeamDark Panel"
APP_URL="https://teamdarkloader.parallaxserver.online"
# Generate: php -r "echo base64_encode(random_bytes(32)), PHP_EOL;"
APP_KEY="CHANGE_ME_BASE64_32_BYTES"
DB_HOST="127.0.0.1"
DB_PORT="3306"
DB_NAME="teamdark_panel"
DB_USER="teamdark_user"
DB_PASS="CHANGE_ME"
SESSION_NAME="TDSSESSID"
# Auto-expire an inactive panel session after 30 minutes.
SESSION_IDLE_SECONDS="1800"
# Rotate the PHP session identifier every 15 minutes.
SESSION_ROTATE_SECONDS="900"
# Require a fresh sign-in at least every 12 hours, even while active.
SESSION_ABSOLUTE_SECONDS="43200"

# Registration/referral credits are disabled unless the policy switch below is explicitly enabled.
REGISTRATION_BONUSES_ENABLED="false"
REFERRER_BONUS="5"
SIGNUP_BONUS="2"

# Cost per started 24-hour period for non-owner key generation.
KEY_COST="1"
# Fixed cost for an unlimited-validity key for non-owner accounts.
UNLIMITED_KEY_COST="100"

# Must match the existing TeamDarkLoader native auth secret from app/src/main/jni/main.cpp.
# Keep this only in the server .env; never return it through HTML/API.
# Existing /connect loader contract is intentionally unchanged by server hardening.
TEAMDARK_AUTH_SECRET="COPY_EXACT_CURRENT_NATIVE_SECRET_HERE"

# Maximum accepted value is capped at seven days by Config.php.
API_TOKEN_TTL="86400"

# Secure defaults. Loader /connect is NOT affected by these switches.
# Keep the legacy JSON license activation API disabled unless a trusted integration still needs it.
LEGACY_LICENSE_API_ENABLED="false"
# API license listings return masked keys by default. Only set true if an owner integration truly
# needs plaintext.
API_REVEAL_LICENSE_KEYS="false"
# Telegram owner bot stays read-only for destructive/mutating controls by default.
TELEGRAM_OWNER_MUTATIONS_ENABLED="false"
# Owner-bot key/referral/chat identifiers stay masked unless explicitly required.
TELEGRAM_OWNER_SENSITIVE_READS_ENABLED="false"
# Linked panel users can view their account/keys and configure 2FA, but key generation stays off by
# default.
TELEGRAM_LINKED_KEY_GENERATION_ENABLED="false"
# Guest/free Telegram key generation is disabled by default to prevent account-farming abuse.
TELEGRAM_GUEST_FREE_KEYS_ENABLED="false"

# Admin privilege controls. Owner remains unrestricted.
ADMIN_BALANCE_ADJUSTMENTS_ENABLED="false"
ADMIN_BALANCE_DAILY_LIMIT="10000"
ADMIN_REFERRAL_BONUS_ENABLED="false"

# Automatic bounded cleanup for security/history tables.
AUDIT_RETENTION_DAYS="90"
BROADCAST_RETENTION_DAYS="30"

# Optional comma-separated trusted reverse-proxy CIDRs. Forwarded client IP headers are ignored unless
# REMOTE_ADDR matches.
# Example for a private nginx proxy: TRUSTED_PROXY_CIDRS="127.0.0.1/32,10.0.0.0/8"
TRUSTED_PROXY_CIDRS=""

# Telegram Bot webhook integration.
# Create a bot with BotFather, keep the token only in server .env.
TELEGRAM_BOT_TOKEN="PASTE_BOTFATHER_TOKEN_HERE"
# Generate: php -r "echo bin2hex(random_bytes(24)), PHP_EOL;"
# Allowed characters for Telegram secret_token: A-Z a-z 0-9 _ -
TELEGRAM_WEBHOOK_SECRET="CHANGE_ME_RANDOM_SECRET"

```

```
# Private Telegram Chat ID that receives Owner-level bot controls.
TELEGRAM_OWNER_CHAT_ID="123456789"
```

7. Configuration constraints enforced by Config.php

- APP_KEY is required and must be valid base64 containing at least 32 random bytes.
- TEAMDARK_AUTH_SECRET, when configured, must be at least 24 characters.
- TELEGRAM_WEBHOOK_SECRET must be 24-256 chars using A-Z, a-z, 0-9, underscore or dash.
- SESSION_IDLE_SECONDS minimum: 300 seconds.
- SESSION_ROTATE_SECONDS minimum: 300 seconds.
- SESSION_ABSOLUTE_SECONDS range: 1800 to 604800 seconds.
- API_TOKEN_TTL range: 300 to 604800 seconds.
- ADMIN_BALANCE_DAILY_LIMIT range: 0 to 1,000,000.
- AUDIT_RETENTION_DAYS and BROADCAST_RETENTION_DAYS range: 7 to 3650 days.

8. Database configuration and schema

The current single schema creates/maintains 16 principal tables:

- panel_settings
- users
- referral_invites
- telegram_users
- license_keys
- license_devices
- balance_ledger
- api_tokens
- telegram_link_tokens
- telegram_2fa_activation_tokens
- login_2fa_challenges
- telegram_update_ids
- announcement_broadcasts
- announcement_recipients
- audit_logs
- rate_limits

Run only database/schema.sql for fresh install and upgrade. Back up first.

The schema uses idempotent add-column/add-index procedures for existing installs and then drops the helper procedures.

- users: role, balance, Telegram link, Telegram 2FA, auth_version and login_not_before.
- referral_invites: one-time invitations with expiry.
- license_keys: encrypted license material, HMAC lookup versioning, validity/device policy.
- license_devices: keyed device identity storage; historical raw identifiers are sanitized.
- api_tokens: bearer token hashes and expiry.
- telegram_link_tokens / telegram_2fa_activation_tokens / login_2fa_challenges: short-lived auth state.
- announcement_broadcasts / announcement_recipients: resumable Telegram announcement queue.
- audit_logs / rate_limits: retained security history and server-side throttling.

9. Owner account creation

```
<?php
declare(strict_types=1);

use TeamDark\Panel\Config, Database, Security;

$root = dirname(__DIR__);
require $root.'/app/Config.php'; require $root.'/app/Database.php'; require $root.'/app/Security.php';
Config::load($root);
if (PHP_SAPI !== 'cli') { fwrite(STDERR, "CLI only\n"); exit(1); }
$user = strtolower(trim($argv[1] ?? ''));
$pass = (string)($argv[2] ?? '');
if (!preg_match('/^[a-z0-9_-]{3,32}$/', $user) || strlen($pass) < 12) {
```

```

        fwrite(STDERR, "Usage: php bin/create-owner.php ownername 'StrongPassword12+'\n"); exit(1);
    }
    $code = 'TD'.strtoupper(bin2hex(random_bytes(6)));
    $stmt = Database::pdo()->prepare("INSERT INTO users(username,password_hash,role,balance,referral_code,
status) VALUES(?,?, 'owner',0,?, 'active')");
    $stmt->execute([$user, Security::passwordHash($pass), $code]);
    echo "Owner created: {$user}\nReferral code: {$code}\n";

```

Operational use:

- ```
php bin/create-owner.php ownername 'StrongPassword12+'
- Username: lowercase a-z, 0-9, dot, underscore or dash, 3-32 chars.
- Password: CLI requires at least 12 characters; use a long unique production password.
- After login, link the Owner Telegram account if Owner bot controls are needed.
- The configured TELEGRAM_OWNER_CHAT_ID must correspond to an active Owner account's
 securely linked Telegram Chat ID.
```

## 10. Telegram bot and webhook

```

<?php
declare(strict_types=1);

use TeamDark\Panel\Config;

$root = dirname(__DIR__);
require $root.'/app/Config.php';

Config::load($root);

$token = (string)Config::get('telegram_bot_token', '');
$secret = (string)Config::get('telegram_webhook_secret', '');
$appUrl = rtrim((string)Config::get('app_url', ''), '/');

if ($token === '') {
 fwrite(STDERR, "TELEGRAM_BOT_TOKEN is missing.\n");
 exit(1);
}

if (!preg_match('/^[A-Za-z0-9_-]{16,256}$/', $secret)) {
 fwrite(
 STDERR,
 "TELEGRAM_WEBHOOK_SECRET must be 16-256 chars using A-Z a-z 0-9 _ - only.\n"
);
 exit(1);
}

if (!preg_match('#^https://#i', $appUrl)) {
 fwrite(STDERR, "APP_URL must be HTTPS for Telegram webhook setup.\n");
 exit(1);
}

$webhookUrl = $appUrl.'/telegram/webhook';

$payload = json_encode([
 'url'=>$webhookUrl,
 'secret_token'=>$secret,
 'allowed_updates'=>['message', 'callback_query'],
 'max_connections'=>20,
 'drop_pending_updates'=>false,
], JSON_UNESCAPED_SLASHES);

$ch = curl_init('https://api.telegram.org/bot'.$token.'/setWebhook');

curl_setopt_array($ch, [
 CURLOPT_POST=>true,
 CURLOPT_POSTFIELDS=>$payload,
 CURLOPT_HTTPHEADER=>['Content-Type: application/json'],
 CURLOPT_RETURNTRANSFER=>true,
 CURLOPT_CONNECTTIMEOUT=>5,
 CURLOPT_TIMEOUT=>15,
 CURLOPT_SSL_VERIFYPEER=>true,
 CURLOPT_SSL_VERIFYHOST=>2,
 CURLOPT_FOLLOWLOCATION=>false,
]);

$body = curl_exec($ch);
$status = (int)curl_getinfo($ch, CURLINFO_RESPONSE_CODE);
curl_close($ch);

$data = is_string($body) ? json_decode($body, true) : null;

```

```

if (
 $status !== 200
 || !is_array($data)
 || !($data['ok'] ?? false)
) {
 fwrite(STDERR, "Telegram setWebhook failed.\n");
 exit(1);
}

echo "Webhook configured: ".$webhookUrl.PHP_EOL;

```

- Webhook URL: APP\_URL + /telegram/webhook.
- APP\_URL must be HTTPS.
- Webhook requests are POST-only and checked against X-Telegram-Bot-API-Secret-Token using constant-time comparison.
- Webhook request body is capped at 1 MiB.
- Bot handles private chats only and verifies sender identity matches the private chat.
- Telegram update IDs are stored for replay protection.
- Per-chat and global server-side rate limits are applied.

## 11. Secure Telegram account linking

- User starts linking from Dashboard and must confirm the current panel password.
- The target Telegram Chat ID must not already belong to another panel account.
- An already linked account cannot silently relink. Securely unlink first.
- If Telegram 2FA is enabled, disable 2FA before changing the linked Telegram identity.
- Current TDLINK format: TDLINK- plus 24 uppercase hex characters (96-bit random token).
- Only an exact private Telegram account can confirm its challenge.
- Link completion increments auth\_version and revokes API tokens.
- Link tokens expire after 15 minutes.

## 12. Optional Telegram 2FA

- 2FA is optional per user and requires a verified Telegram link.
- Bot activation key format: TD2FA- plus 12 uppercase hex characters.
- Activation key lifetime: 10 minutes.
- Login OTP: exactly 8 digits, single-use.
- OTP lifetime: 5 minutes.
- Maximum wrong attempts per challenge: 5.
- OTP is stored as an APP\_KEY-backed keyed hash, not plaintext.
- New challenges invalidate earlier unused challenges.
- 2FA enable/disable/reset and Telegram unlink revoke API tokens and bump auth\_version.
- User cannot unlink Telegram while 2FA is enabled.
- User disable requires current password; Owner recovery can reset 2FA.

### API 2FA continuation

- API password login returns 2FA\_REQUIRED with challenge\_id, user\_id and a base64url continuation\_token.
- Continuation token is derived from 32 random bytes and is HMAC-bound to the challenge.
- POST /api/v1/auth/2fa requires the continuation token plus challenge\_id, user\_id and OTP.
- Web-created 2FA challenges cannot be reused to mint API bearer tokens.

## 13. User roles and authority

- Owner: highest authority; can manage non-Owner users, settings, announcements, recovery and system controls.
- Admin: may create User referrals; privileged actions require fresh authentication. Secure defaults disable Admin balance mutation unless explicitly enabled.
- Reseller: limited key/account visibility within permitted relationships.
- User: self-owned license and account operations.
- Role/status changes revoke stale authorization and pending referrals that the creator is no longer authorized to issue.
- Owner cannot be managed through ordinary non-Owner target flows.

## 14. License/key configuration

- Generated key format: Team-Dark- plus a 16-character high-entropy restricted alphabet token.
- Custom keys: 24-80 chars, allowed A-Z a-z 0-9 . \_ -, and must include uppercase, lowercase and a digit.
- Device limits: 1, 2, 5, 10, 20, 30, 50, 100, 500, 1000, or unlimited.
- Timed key pricing: KEY\_COST per started 24-hour period for non-Owner accounts.
- Unlimited validity: UNLIMITED\_KEY\_COST for non-Owner accounts.
- Generated key lookup hash: APP\_KEY-backed HMAC, key\_hash\_version=2.
- Plain license value at rest: AES-256-GCM.
- Legacy SHA-256 lookup hashes are transparently upgraded to HMAC during authentication.
- Delegated Admin/Reseller web views do not reveal another user's plaintext license secret.
- First successful Loader login starts the validity timer.

## 15. Native Loader /connect compatibility contract

Do not alter this contract as part of panel configuration.

- Method: POST.
  - Content-Type: application/x-www-form-urlencoded.
  - Fields: game, user\_key, serial.
  - Expected game: PUBG.
  - Endpoint example: <https://teamdarkloader.parallaxserver.online/connect>.
  - Request body is capped at 4096 bytes.
  - Per-IP server rate limit: 300 requests / 60 seconds.
  - Protocol-level failures intentionally remain HTTP 200 because the existing native Loader parses the JSON reason only for successful HTTP responses.
  - Keep existing status/reason/data JSON shape and token formula unchanged.
- Panel hardening should never require changing Loader C++, request fields, token formula or response contract.

## 16. Panel JSON API

- POST /api/v1/auth/login: username/password; 2FA-enabled accounts return a continuation challenge.
- POST /api/v1/auth/2fa: verifies continuation + OTP and issues bearer token.
- GET /api/v1/me: authenticated user info.
- GET /api/v1/licenses: masked license values by default.
- Plaintext API license output requires Owner role AND API\_REVEAL\_LICENSE\_KEYS=true.
- Legacy /api/v1/license/activate and /api/v1/license/validate are disabled by default with LEGACY\_LICENSE\_API\_ENABLED=false.
- API bearer tokens are stored only as hashes and expire according to API\_TOKEN\_TTL.

## 17. Owner server controls

Owner settings are stored in panel\_settings.settings\_json with optimistic revision control to reject stale form overwrites.

- panel\_online: master human panel availability switch. Owner retains access for recovery.
- registration\_open: controls new referral registration.
- generation\_open: controls non-Owner and guest generation.
- message: maintenance message, maximum 500 bytes.
- announcement: live web-panel announcement.
- splash\_enabled/title/subtitle/duration/version: opening splash controls.
- Owner/Admin sensitive routes use a 5-minute fresh-auth window where applicable.

## 18. Announcement broadcasting

- Owner can publish to Panel users, linked Telegram users, guest/free Telegram users, or any combination.

- Recipients are snapshotted into announcement\_recipients.
- Delivery is resumable and tracks pending/sending/sent/failed states.
- Broadcast history retention is controlled by BROADCAST\_RETENTION\_DAYS.
- Announcement text is limited to 1000 bytes.
- Publishing/clearing require Owner authority, CSRF and fresh authentication.

## 19. Opening splash

- Owner can enable/disable global web splash.
- Default title: TEAM DARK.
- Default subtitle: Secure control plane.
- Default duration: 2400 ms.
- Allowed durations: 1400, 2000, 2400, 3200, 4200 ms.
- Title maximum: 60 bytes; subtitle maximum: 160 bytes.
- Splash version increments when configuration changes so the new intro can show again.
- Splash applies to human web pages only; /connect, JSON APIs and Telegram webhook are not modified.

## 20. Sessions, passwords and access revocation

- Session cookie is HttpOnly and SameSite=Strict; Secure when HTTPS is detected.
- Session IDs rotate periodically; strict cookie-only sessions are enabled.
- Idle timeout defaults to 1800 seconds; rotation 900; absolute lifetime 43200.
- auth\_version invalidates older browser sessions after sensitive changes.
- Self-service password rotation requires current password, changes password hash, bumps auth\_version, deletes API tokens and pending login challenges, and preserves only the initiating hardened session.
- Owner password reset revokes target access.
- 2FA/Telegram identity changes are security state transitions and revoke stale API access.

## 21. Recommended security policy switches

- REGISTRATION\_BONUSES\_ENABLED=false - Prevents referral/signup credit farming unless intentionally enabled.
- LEGACY\_LICENSE\_API\_ENABLED=false - Keeps legacy JSON license endpoints unavailable.
- API\_REVEAL\_LICENSE\_KEYS=false - Prevents plaintext license disclosure through API.
- TELEGRAM\_OWNER\_MUTATIONS\_ENABLED=false - Keeps high-risk Owner mutation actions out of Telegram by default.
- TELEGRAM\_OWNER\_SENSITIVE\_READS\_ENABLED=false - Masks keys/referrals/chat IDs in Owner bot views.
- TELEGRAM\_LINKED\_KEY\_GENERATION\_ENABLED=false - Prevents bot-side licensed key generation unless intentional.
- TELEGRAM\_GUEST\_FREE\_KEYS\_ENABLED=false - Prevents guest-account key farming unless intentional.
- ADMIN\_BALANCE\_ADJUSTMENTS\_ENABLED=false - Prevents Admin credit minting by default.
- ADMIN\_REFERRAL\_BONUS\_ENABLED=false - Prevents Admin referral bonus farming by default.
- AUDIT\_RETENTION\_DAYS=90 - Default audit retention.
- BROADCAST\_RETENTION\_DAYS=30 - Default completed broadcast retention.

## 22. HTTPS and trusted reverse proxy

- APP\_URL should be the final canonical https:// origin.
- The panel emits HSTS on HTTPS plus no-store, CSP, X-Frame-Options DENY, nosniff and other security headers.
- Forwarded client IP/proto headers are trusted only when REMOTE\_ADDR belongs to TRUSTED\_PROXY\_CIDRS.
- For a private reverse proxy example: TRUSTED\_PROXY\_CIDRS="127.0.0.1/32,10.0.0.0/8".
- Do not blindly trust arbitrary X-Forwarded-For / X-Forwarded-Proto from public clients.
- Cloudflare/nginx edge limits should supplement, not replace, application rate limiting.



## 23. File permissions and secret handling

- Never commit production .env.
- Keep app/, bin/, database/, tests/ and .env outside the web document root.
- Use owner-readable filesystem permissions; avoid world-readable secret files.
- Keep MySQL root credentials out of the application.
- Do not print APP\_KEY, DB\_PASS, TELEGRAM\_BOT\_TOKEN, TELEGRAM\_WEBHOOK\_SECRET or TEAMDARK\_AUTH\_SECRET in UI, logs, screenshots or support dumps.
- Do not rotate APP\_KEY casually; it protects encrypted/HMAC state.
- Keep server error details in server logs; return generic browser/API errors.

## 24. Audit, rate limits and retention

- Security actions are written to audit\_logs with actor, action, IP, user-agent and sanitized JSON metadata.
- Audit failures are fail-safe: logging problems should not take the user request down.
- Bounded cleanup removes old audit records according to AUDIT\_RETENTION\_DAYS.
- Completed/partial/cancelled broadcast history is cleaned according to BROADCAST\_RETENTION\_DAYS.
- Expired API tokens and old auth challenges are cleaned opportunistically.
- Rate limits are stored server-side and stale buckets are periodically removed.

## 25. Backup and restore

- Before every schema or security deployment: dump the database and copy the current .env.
- Store APP\_KEY backup securely and separately from the public web tree.
- Test restore procedures on a non-production database.
- After restore, verify owner login, Telegram webhook, 2FA, license decryption and /connect.
- If restoring to another host, update APP\_URL / trusted proxy configuration but preserve cryptographic secrets unless performing a planned rotation.

## 26. Deployment checklist

- [ ] Database backup completed.
- [ ] .env backup completed and production secrets not committed.
- [ ] Branch files deployed.
- [ ] database/schema.sql imported successfully.
- [ ] APP\_URL points to final HTTPS origin.
- [ ] Document root points to teamdark-panel/public only.
- [ ] Production display\_errors disabled.
- [ ] Telegram webhook configured if used.
- [ ] Owner login works.
- [ ] Telegram link and optional 2FA tested.
- [ ] Key creation and first-use activation tested.
- [ ] /connect valid and invalid cases tested without response-contract changes.
- [ ] Admin/Owner fresh-auth behavior tested.
- [ ] Announcement/splash tested if enabled.
- [ ] File permissions and secret exposure reviewed.

## 27. Validation checklist

- [ ] GET /login loads over HTTPS.
- [ ] Owner authenticates and reaches Dashboard.
- [ ] Owner settings can be read and saved.
- [ ] Registration respects registration\_open and a valid non-expired referral.
- [ ] Telegram link requires current password and exact Telegram verification.
- [ ] 2FA sends an 8-digit OTP and rejects replay.
- [ ] API 2FA rejects wrong/missing continuation tokens.
- [ ] Create a disposable license and verify first Loader use starts its timer.
- [ ] Block/unblock and reset devices on the test license.

- [] Call /connect with missing fields and verify JSON compatibility.
- [] Call /connect with a valid disposable key and verify Loader-compatible success.
- [] Sensitive Telegram Owner views remain masked with secure defaults.
- [] Admin balance mutation is blocked while ADMIN\_BALANCE\_ADJUSTMENTS\_ENABLED=false.
- [] Legacy JSON license API is unavailable while LEGACY\_LICENSE\_API\_ENABLED=false.
- [] Audit trail records security actions without passwords/tokens/license secrets.

## 28. Troubleshooting

### SQLSTATE[HY000] [1045] Access denied

Check DB\_USER, DB\_PASS, host permissions and whether the MySQL account is allowed from localhost. Test the same credentials with the mysql CLI.

### APP\_KEY error on startup

Generate valid base64 containing at least 32 random bytes. Do not use a human password as APP\_KEY.

### Telegram webhook setup fails

APP\_URL must be HTTPS. Verify bot token, webhook secret format, DNS/TLS and outbound access to api.telegram.org.

### Owner bot menu denied

TELEGRAM\_OWNER\_CHAT\_ID must match a Telegram Chat ID securely linked to an active Owner panel account.

### Cannot relink Telegram

Expected security behavior. Disable 2FA, securely unlink using current password, then link the new Telegram account.

### 2FA code not received

Check the linked Chat ID, bot token, Telegram reachability and server logs. A new challenge invalidates the previous unused challenge.

### API 2FA says invalid/expired

Use the continuation\_token from the same /api/v1/auth/login response. Do not reuse a web challenge.

### Admin cannot adjust balance

Secure default. Enable ADMIN\_BALANCE\_ADJUSTMENTS\_ENABLED only if intentionally required; the daily positive limit still applies.

### Guest bot cannot generate a free key

Secure default. TELEGRAM\_GUEST\_FREE\_KEYS\_ENABLED is false unless explicitly enabled.

### /connect Invalid Key

Check the license value, status, expiry and account status. Do not add extra fields or change the native contract.

### HTTPS redirects loop behind proxy

Configure TRUSTED\_PROXY\_CIDRS to the actual direct proxy CIDR and ensure the trusted proxy sends X-Forwarded-Proto=https.

### Old encrypted keys break after deployment

Most commonly APP\_KEY was changed. Restore the original APP\_KEY or perform a planned migration.

## 29. Secret rotation and incident response

- DB password: rotate MySQL account and .env together.
- Telegram bot token: revoke/regenerate in BotFather, update .env, rerun set\_telegram\_webhook.php.

- Telegram webhook secret: generate new random secret, update .env, rerun webhook setup.
- APP\_KEY: high-impact rotation; requires planned migration of encrypted/HMAC-protected state.
- TEAMDARK\_AUTH\_SECRET: native compatibility secret; rotation requires synchronized Loader change. Current configuration preserves it.
- Owner password: rotate from panel/CLI recovery as appropriate; session/API revocation should follow.

If .env is exposed, treat DB credentials, bot token, webhook secret, APP\_KEY and native auth secret as compromised. Contain server access first, then rotate according to dependency impact.

## 30. Quick production reference

- Web root: teamdark-panel/public only
- HTTPS: Required; APP\_URL=https://...
- APP\_KEY: 32+ random bytes, base64, preserved across normal upgrades
- Database: Dedicated non-root user; localhost/firewalled
- Legacy JSON license API: OFF
- API plaintext license reveal: OFF
- Telegram Owner mutations: OFF
- Telegram Owner sensitive reads: OFF
- Linked bot key generation: OFF unless needed
- Guest free keys: OFF unless needed
- Admin balance adjustment: OFF unless needed
- Registration bonuses: OFF unless needed
- Audit retention: 90 days default
- Broadcast retention: 30 days default
- Owner account: Long unique password + securely linked Telegram + optional 2FA
- /connect: Do not change request fields, token formula or response contract

## END OF CONFIGURATION GUIDE

Generated from ZayYadav/KeshavNoRule / TeamDarkLoader-final-panel-security

Source head used for this document: 2e7ea2705fad2ceb3844566a96559009d76458f6

This repository PDF contains no production secrets.